

QUANTUM READY · GUILDFORD, SURREY

Operating Guide

How to run the scanner, read the report it produces, and turn it into paying client work. Written to be followed start to finish with nothing assumed.

Version 1.0

For: Darshan Chabbi, Kiran Pun, Bhanu Teja Battula

Covers: setup · running a scan · reading results · selling the service

What's in here

01	What this thing actually is	In plain English
02	Setting it up, once	Python, then the code
03	The easy way — the dashboard	Type a domain into a box
04	The command-line way	One line, more control
05	What happens while it runs	The six stages, live
06	Reading the report	What every number means
07	Saving and sending it	Four output formats
08	Selling this to clients	Who, what to say, what to charge
09	The line you must not cross	Permission before scanning
10	When something breaks	Errors and their fixes
11	Quick reference	Every command on one page

What this thing actually is

You give it a company's web address. It tells you how badly that company would be hurt by a quantum computer, and what to fix first.

Here is the problem it exists to solve, in one paragraph.

Almost all encryption on the internet today is protected by maths that a quantum computer can solve. Not *weaken* — **solve**. When that machine arrives, everything protected by RSA or elliptic-curve cryptography becomes readable. And because attackers can record encrypted traffic *today* and decrypt it later, data that must stay secret for ten years is already exposed, right now, before the machine exists. That is called **harvest now, decrypt later**.

The UK's National Cyber Security Centre has set three dates: a full inventory of your cryptography by **2028**, your highest-priority systems migrated by **2031**, and everything done by **2035**. Those dates turn this from an interesting idea into a job somebody has to do.

What the scanner does about it

It connects to a company's public servers and records what they actually negotiate — not what a policy document claims. From that it produces a risk score, a list of specific problems, an inventory of every algorithm in use, and a prioritised plan.

THE ONE SENTENCE THAT SELLS IT

Everyone else sends a questionnaire. You send evidence — measured from the outside, in about ten seconds, before the client has signed anything.

Two ways to run it

WAY	BEST FOR	SECTION
The dashboard	Demos, client meetings, anyone who dislikes terminals. You type a domain into a box on a web page.	Section 3
The command line	Saving reports to files, scanning many domains, anything repeatable.	Section 4

They run the same engine and produce the same results. Start with the dashboard.

Setting it up, once

Two things to install: Python, then the scanner itself. You do this once per computer, and never again.

GOOD NEWS

The scanner has **zero dependencies**. There is no long list of libraries to install and nothing that can break next month. If you have Python, you have everything.

Step one — install Python

1 Check whether you already have it.

Open **Terminal** (Mac) or **PowerShell** (Windows) and type:

```
python3 --version
```

If you see `Python 3.9` or higher, skip to step two. On Windows you may need `python --version` instead.

2 If you don't have it,

download it from `python.org/downloads` and run the installer. **On Windows, tick "Add Python to PATH"** on the first screen — if you miss it, nothing below will work.

3 Close and reopen your terminal,

then check the version again.

Step two — get the scanner

If you have the code as a folder already, just move it somewhere sensible and skip ahead. To pull it from GitHub:

```
# download the code
git clone https://github.com/kiranpun/agile-mosca-pqc.git

# move into the folder – every command later assumes you are here
cd agile-mosca-pqc
```

WINDOWS POWERSHELL: ONE IMPORTANT DIFFERENCE

PowerShell does not accept `&&` between commands. If you copy a line containing `&&` from anywhere, it will fail. Run each command on its own line instead. Every command in this guide is already written one per line.

Step three — check it works

```
python3 -m quantumready --help
```

You should see a list of commands: `scan`, `serve`, `study`, `mosca`, `algorithms`. If you do, setup is finished and you never have to do it again.

IF IT SAYS "NO MODULE NAMED QUANTUMREADY"

You are in the wrong folder. The command only works from inside `agile-mosca-pqc` — the folder that contains a folder called `quantumready`. Type `cd` and the path to it, then try again.

The easy way — the dashboard

This is where you put the domain. It's a web page with a box on it. Use this in front of clients.

Start it

```
python3 -m quantumready serve
```

Your browser opens automatically at `http://127.0.0.1:8080`. If it doesn't, open that address yourself. Leave the terminal window open — closing it stops the dashboard.

QuantumReady

Scan a company's public estate for quantum-vulnerable cryptography, certificate and TLS weaknesses, licence exposure, and compliance gaps.

COMPANY DOMAIN

acme.co.uk

ORGANISATION NAME **SECTOR** **DATA SHELF LIFE (YEARS)** **MIGRATION TIME (YEARS)**

optional General (10y) 10 5

THREAT TIMELINE **MAX HOSTS**

Central (2035) 8

Run scan a common default; replace it with your real retention obligation

Assesses the externally visible estate only. Internal systems, VPNs, code signing and backups need a separate inventory — which is what the NCSC 2028 discovery phase asks for. Compliance mappings are for orientation, not legal advice.

The dashboard. The domain goes in the top box – everything else has a sensible default.

Fill it in

FIELD	WHAT TO PUT	NEEDED?
Company domain	Just the domain — <code>acme.co.uk</code> . No <code>https://</code> , no <code>www</code> , no trailing slash.	Yes
Organisation name	The client's legal name. It appears at the top of the report, so fill it in for anything you'll send.	No
Sector	Sets how long their data must stay secret. Healthcare, defence and finance default to much longer than general.	No
Data shelf life	Years the data must stay confidential. Use their longest legal retention obligation.	No
Migration time	Years to actually migrate. Five is realistic for a mid-size organisation; ten for anything with heavy legacy.	No
Threat timeline	When you assume a quantum computer arrives. Leave on Central (2035) — that's the NCSC line, and it's defensible.	No
Max hosts	How many servers to check. Eight is fine. Raise it for large estates, but the scan takes longer.	No

Press **Run scan**. Progress appears live. Results appear on the same page in about ten to sixty seconds depending on the size of the estate.

STOPPING IT

Click the terminal window and press **Ctrl + C**.

The command-line way

Same engine, but it can write report files you can email. This is what you'll use for real client work.

The simplest possible scan

```
python3 -m quantumready scan acme.co.uk
```

Replace `acme.co.uk` with any domain. Results print in the terminal. Nothing is saved.

A real client scan, saved to files

```
python3 -m quantumready scan acme.co.uk \  
  --org "Acme Ltd" \  
  --sector finance \  
  --html-out acme-report.html \  
  --json-out acme-data.json
```

ON WINDOWS, DON'T USE THE BACKSLASHES

The `\` at the end of a line means "continues below" on Mac and Linux only. In PowerShell, put the whole thing on **one long line** with no backslashes at all.

That writes `acme-report.html` into the folder you're in. Double-click it to open it — that file is the thing you send the client.

The options you'll actually use

OPTION	WHAT IT DOES
<code>--org "Name"</code>	Puts the client's name on the report.
<code>--sector finance</code>	Sets data shelf life. The full list: defence, education, finance, general, government, healthcare, insurance, legal, pharmaceutical, retail, technology.
<code>--html-out FILE</code>	Writes the report you send to clients.
<code>--json-out FILE</code>	Writes the raw data, for your own tooling.
<code>--markdown-out FILE</code>	Writes text for tickets and wikis.
<code>--cbom-out FILE</code>	Writes a CycloneDX cryptographic bill of materials.
<code>--fast</code>	Skips deep protocol probing. Roughly three times quicker, slightly less detail. Good for demos.
<code>--max-hosts 20</code>	Checks more servers. Default is 12.
<code>--no-ct</code>	Skips Certificate Transparency host discovery.
<code>--shelf-life 25</code>	Sets data shelf life directly, in years.
<code>--quiet</code>	Hides the live progress output.

Two other commands worth knowing

```
# the X + Y > Z deadline calculation on its own, no scanning
python3 -m quantumready mosca --shelf-life 25 --migration-years 5

# what post-quantum tooling exists today
python3 -m quantumready algorithms
```

What happens while it runs

Six stages, in order, each feeding the next. This is the real output from a real scan — so you know what normal looks like.

```
Quantum.Ready – scanning example.com

[ 2%] discovery
      Discovering hosts for example.com
[ 10%] 2 host(s) to assess

[ 12%] tls
      Assessing TLS on 2 host(s)
[ 34%] example.com: TLSv1.3, no PQC
[ 57%] www.example.com: TLSv1.3, no PQC

[ 60%] http
      Checking HTTP security controls
[ 76%] dns
      Checking DNS posture for example.com
[ 86%] licences
      Inventorying components and licences
[ 93%] analysis
      Scoring and building the report

[100%] done
      Scan complete in 5.6s
```

What each stage is doing

STAGE	IN PLAIN ENGLISH
1 • Discovery	Finds every server they own. Public certificate logs record every certificate ever issued for a domain, so they double as a list of forgotten servers. Anything that no longer exists is dropped.
2 • TLS	The important one. Connects to each server for real and records what it actually agrees to — certificates, key sizes, protocol versions, ciphers, and whether it supports post-quantum key exchange.
3 • HTTP	Checks the web security headers — whether HTTPS is enforced, whether HSTS is set.
4 • DNS	Checks who can issue certificates and send email as them — DNSSEC, CAA, SPF, DMARC. Email spoofing sits behind most invoice fraud.
5 • Licences	Identifies third-party components and their licence obligations.
6 • Analysis	Now it judges. Everything above becomes findings, a score, a deadline and a plan. Nothing is scored before this point.

WHY "NO PQC" IS THE LINE THAT MATTERS

In the output above, `no PQC` means that server does not support post-quantum key exchange. Everything it sends today can be recorded now and read later. That single phrase is the whole business in two words.

Reading the report

Four things to look at, in this order: the scores, the deadline, the findings, and the plan.

1 — The two scores

Security score	0/100 (grade F)
Quantum readiness	10/100 (grade F)
Findings	8 high 6 medium 2 low
Hosts assessed	2

Security score is how they're doing today, against today's threats. **Quantum readiness** is how they'd survive a quantum computer. They are separate on purpose: an organisation can be perfectly secure today and completely unready for 2035.

A / B

Genuinely good. Rare.

C / D

Typical. Real work needed.

E / F

Serious gaps. Most first scans land here.

SET EXPECTATIONS BEFORE YOU SHOW A CLIENT THEIR GRADE

Almost every first scan comes back E or F, because nobody has migrated yet. An F is not an insult — it's the industry baseline in 2026. Say so before you show the number, or you will put the client on the defensive in the first thirty seconds.

2 — The deadline

MOSCA: **EXPOSED** $X(10) + Y(5) = 15 > Z(8.4)$

Read it as: their data must stay secret **10 years**, migration takes **5 years**, so they need **15 years** of protection — but only **8.4 years** remain before the assumed threat date. The shortfall is **6.6 years**. They are already late.

This is the number that creates urgency, and it's arithmetic rather than opinion, which is exactly why it works in a boardroom.

3 — The findings

```
HIGH      Q  Certificate key (RSA-2048) is breakable by a quantum computer
            example.com:443
HIGH      Q  No post-quantum key exchange offered
            example.com:443
MEDIUM    Certificate expires in 21 days
            example.com:443
```

Each line is one problem on one server. The **Q** marks findings that are specifically quantum-related, as opposed to ordinary security hygiene. Both matter, and separating them lets you have two different conversations.

4 — The plan

```
Do these first
1. Enable HTTP Strict Transport Security      hours · immediate
2. Redirect all plaintext HTTP to HTTPS      hours · immediate
3. Enable hybrid post-quantum key exchange   days  · 2031
4. Plan certificate migration to ML-DSA      months · 2035
```

Ordered by impact, with an effort estimate and the deadline each one belongs to. The first two are usually free and take an afternoon — **which is your way in. Give those away.** Items three and four are the paid work.

Saving and sending it

Four formats. You will mostly use the first.

FORMAT	FLAG	USE IT FOR
HTML	<code>--html-out</code>	The client deliverable. Self-contained — email the file, it opens in any browser. This is what you send.
Markdown	<code>--markdown-out</code>	Pasting into Jira, Notion, Confluence or an internal wiki.
JSON	<code>--json-out</code>	Feeding your own tools, tracking a client's score over time, building dashboards.
CycloneDX	<code>--cbom-out</code>	A cryptographic bill of materials in an industry-standard format. Larger clients will specifically ask for this — it's what the NCSC 2028 inventory requirement actually wants.

Turning the HTML into a PDF

Open the HTML file in Chrome, press **Ctrl + P** (or **⌘ + P**), and choose **Save as PDF**.

Some clients want PDFs for their records.

NAME FILES SO YOU CAN FIND THEM IN A YEAR

Use `clientname-YYYY-MM-DD.html`. When you re-scan the same client in six months, being able to show the improvement is a renewal conversation that writes itself.

Selling this to clients

The scan is not the product. The scan is what gets you in the room. The product is the migration work that follows.

Who to approach, and why they have to listen

Target organisations that hold data with a long confidentiality life *and* have someone accountable for compliance. That combination is what converts.

WHO	WHY THEY CAN'T IGNORE IT
NHS trusts	Patient records must stay confidential for decades. Their shelf life alone puts them years past the deadline.
Local councils	Public accountability, statutory retention, and small security teams. High need, low internal capacity.
Universities	Research data, large sprawling estates, and lots of forgotten servers that discovery will find.
Listed companies	Board-level cyber disclosure duties. "We were told and did nothing" is a governance problem, not just a technical one.
Legal & financial firms	Client confidentiality obligations lasting decades, plus regulators who already ask about cryptography.

The route from stranger to signed

- 1

Scan first, ask second.

Run the scan on a prospect before you contact them — but read Section 9 first, because how you do this matters.
- 2

Lead with one specific fact.

Not "we do post-quantum consulting." Instead: "your main web server doesn't support post-quantum key exchange, and your certificates expire in 21 days." Specific beats generic every time.
- 3

Give the report away free.

It costs you ten seconds of compute. It's the most persuasive marketing asset you will ever have, because it's about them.
- 4

Fix something small for free.

The top two findings are usually an afternoon's work. Doing that buys enormous trust and costs almost nothing.
- 5

Sell the inventory.

The free scan only sees the outside. NCSC's 2028 requirement is a *complete* inventory — internal systems, VPNs, databases, code signing. That's a paid engagement, and the scan proves you can do it.

6 Sell the migration.

The inventory produces a roadmap. The roadmap produces years of work. This is where the actual revenue is.

What to say

COLD EMAIL – KEEP IT THIS SHORT

Subject: Your certificates and the 2035 deadline

Hello [name] — I ran a passive check of [company]'s public web estate against the NCSC's post-quantum migration timeline. Two things stood out: none of your public servers currently offer post-quantum key exchange, and [specific second finding].

I've attached the full report — no charge, no obligation. If it's useful, I'm happy to walk you through it for twenty minutes. If not, please ignore this and keep the report.

THE TWENTY-MINUTE CALL – THE ONLY THREE POINTS YOU NEED

"Encryption you're using today is recorded today and read later. So the clock started before the machine exists."

"Your data has to stay secret for [X] years. Migration takes about [Y]. That's more time than you have left. Here's the arithmetic." — show the Mosca line

"The NCSC wants a full inventory by 2028. This scan covers your outside. The inside is where the hard cases are, and that's what I'd help with."

Objections you will get

"Quantum computers don't exist yet. This is years away."

Agreed — and that's precisely why it's urgent. Encrypted traffic is being recorded now to be decrypted later. If your data must stay secret for ten years, you're already inside the window. Also, migration itself takes years; starting when the machine arrives means finishing a decade late.

"Can't we just use bigger keys?"

No, and this is the single most common misunderstanding. RSA-15360 falls to exactly the same algorithm as RSA-2048 — it just takes marginally longer. The migration replaces the mathematics; it doesn't resize it. Anyone advising you to increase key length has misunderstood the threat.

"Our vendor says they've handled it."

Excellent — then this scan will confirm it in ten seconds, and you'll have evidence rather than an assurance. If they have handled it, we'll see post-quantum key exchange on your endpoints. Shall we look?

"We have no budget for this."

Understood. The first two fixes in this report cost nothing but an afternoon of a sysadmin's time — do those regardless. When 2028 inventory planning reaches your agenda, you'll have a starting point and my number.

How to structure what you charge

YOU SET THESE NUMBERS, NOT ME

The *shape* below is the standard consulting ladder and is sound. The actual figures depend on your costs, your market and your confidence — decide them deliberately rather than adopting a number from a document.

STAGE	WHAT THEY GET	PRICING SHAPE
External scan	The report this tool produces	Free. It's the lead magnet — never charge for it.
Readout call	Twenty minutes walking them through it	Free. This is the sales conversation.
Full inventory	Internal systems, VPNs, code signing, databases — the real NCSC 2028 deliverable	Fixed fee, scoped by estate size
Migration roadmap	Prioritised plan with costs and sequencing	Fixed fee, or bundled with the inventory
Migration delivery	Doing the work, or overseeing those who do	Day rate or retainer — this is the revenue
Annual re-assessment	Proof of progress for the board	Recurring. Highest-margin thing you'll sell.

YOUR GENUINE ADVANTAGE

Most competitors in this space sell a questionnaire and a slide deck. You arrive with measurements taken from the client's own servers, before the first meeting. Lead with that difference — it is the whole reason someone picks you.

The line you must not cross

Read this before you scan anyone you don't have a relationship with. Getting it wrong damages your reputation faster than the tool builds it.

Not all scanning is equal, and it's worth being precise rather than nervous.

WHAT	STANDING
Reading Certificate Transparency logs and DNS records	Entirely public. These are public registries. You're reading published records, not touching their systems.
One HTTPS connection to a public web server	Ordinary. This is exactly what a browser does when anyone visits the site. A public web server exists to accept connections.
Full cipher enumeration across many hosts	Be careful. Dozens of connections in quick succession can trip intrusion detection and will look like probing to a security team who don't know you.
Any paid engagement	Get written authorisation, always. No exceptions, ever.

THE RULES – FOLLOW THESE AND YOU WILL NOT HAVE A PROBLEM

1. For paid work, get written permission naming the domains and the dates, signed by someone with authority to give it. Put it in the contract.
2. For prospecting, use `--fast` and a low `--max-hosts`. It's lighter on their servers and there is no reason to be heavy-handed before anyone has hired you.
3. Never scan anything that isn't the public web estate. This tool doesn't do intrusive testing — don't reach for tools that do without a contract.
4. If anyone asks you to stop, stop immediately and confirm in writing.
5. Send findings to the organisation privately. Never publish a named company's weaknesses to make a marketing point.

The reputational risk is the one that will actually bite you. A security firm that scans people uninvited and then emails about it can read as hostile — and the security community talks. Frame every unsolicited report as a gift with no obligation, keep the footprint light, and stop the moment anyone objects.

SAY THIS PLAINLY ON YOUR WEBSITE AND IN EVERY EMAIL

"We only scan domains you're authorised to have assessed." It sets the expectation, it's true, and it costs you nothing.

When something breaks

Every error we've actually hit, and what fixes it.

WHAT YOU SEE	WHAT IT MEANS AND WHAT TO DO
No module named quantumready	You're in the wrong folder. <code>cd</code> into <code>agile-mosca-pqc</code> — the one containing a <code>quantumready</code> folder — and retry.
python3: command not found	On Windows try <code>python</code> instead. If that also fails, Python isn't installed or wasn't added to PATH — reinstall and tick that box.
The token '&&' is not a valid statement separator	PowerShell. Run each command on its own line.
Scan hangs or times out	The domain may be unreachable or behind a firewall. Add <code>--timeout 15</code> , or <code>--fast</code> to reduce the work.
Report says the certificate issuer is something unexpected	You're behind a corporate proxy that intercepts HTTPS. The results describe the proxy, not the target. Re-run from a normal network. The scanner detects and flags this rather than reporting the proxy's settings as the client's.
0 component(s) identified	Normal, not an error. The site bundles its assets, which hides component identity from any external scan. It's noted in the report.
Everything comes back grade F	Also normal. Almost nobody has migrated yet — that's the business opportunity, not a bug.

SECTION 11

Quick reference

Everything on one page. Print this one and keep it by the desk.

SETUP, ONCE

```
python3 --version
git clone https://github.com/kiranpun/agile-mosca-pqc.git
cd agile-mosca-pqc
python3 -m quantumready --help
```

THE DASHBOARD – FOR DEMOS AND CLIENT MEETINGS

```
python3 -m quantumready serve
# then open http://127.0.0.1:8080 and type the domain in the top box
# Ctrl+C in the terminal to stop
```

A QUICK LOOK AT ANY DOMAIN

```
python3 -m quantumready scan acme.co.uk --fast
```

A FULL CLIENT SCAN, SAVED AND READY TO SEND

```
python3 -m quantumready scan acme.co.uk --org "Acme Ltd" --sector finance --html-out acme-2026-08-15.html
```

EVERY OUTPUT FORMAT AT ONCE

```
python3 -m quantumready scan acme.co.uk --html-out r.html --json-out r.json --markdown-out r.md
--cbom-out cbom.json
```

THE DEADLINE CALCULATION ALONE

```
python3 -m quantumready mosca --shelf-life 25 --migration-years 5
```

THE NUMBERS TO REMEMBER

NUMBER	WHAT IT IS
0 bits	RSA's security against a quantum computer, at any key size
2028	NCSC deadline for a complete cryptographic inventory
2031	NCSC deadline for migrating highest-priority systems
2035	NCSC deadline for completing migration
X + Y > Z	Mosca's inequality. Shelf life plus migration time against time remaining. If it's true, they're already late.
FIPS 203/204/205	The NIST post-quantum standards: ML-KEM, ML-DSA, SLH-DSA